

IT Security Manual — Password & Access Policy

1. Password Requirements

All employee passwords must be at least 14 characters long and include a mix of uppercase letters, lowercase letters, numbers, and symbols. Passwords must be changed every 90 days and may not reuse any of the previous 10 passwords.

2. Multi-Factor Authentication

Multi-factor authentication (MFA) is mandatory for all accounts with access to production systems, customer data, or financial systems. Approved MFA methods include authenticator apps (preferred) and hardware security keys. SMS-based MFA is not permitted for privileged accounts.

3. Access Provisioning

New employee accounts are provisioned within 1 business day of their start date, with access scoped to the minimum required for their role (principle of least privilege). Access reviews are conducted quarterly by team leads, and any unused access must be revoked within 5 business days of identification.

4. Incident Reporting

Any suspected security incident (phishing email, lost device, unauthorized access) must be reported to the Security team within 1 hour of discovery via the #security-incidents Slack channel or security@company.example. Do not attempt to investigate suspected compromises independently.

5. Device Encryption

All company-issued laptops must have full-disk encryption enabled. Personal devices used to access company email or documents must be enrolled in the Mobile Device Management (MDM) system before access is granted.

6. Third-Party Vendor Access

Vendors requiring access to internal systems must sign a data processing agreement and undergo a security review before provisioning. Vendor access is automatically revoked 90 days after the contract end date unless renewed.